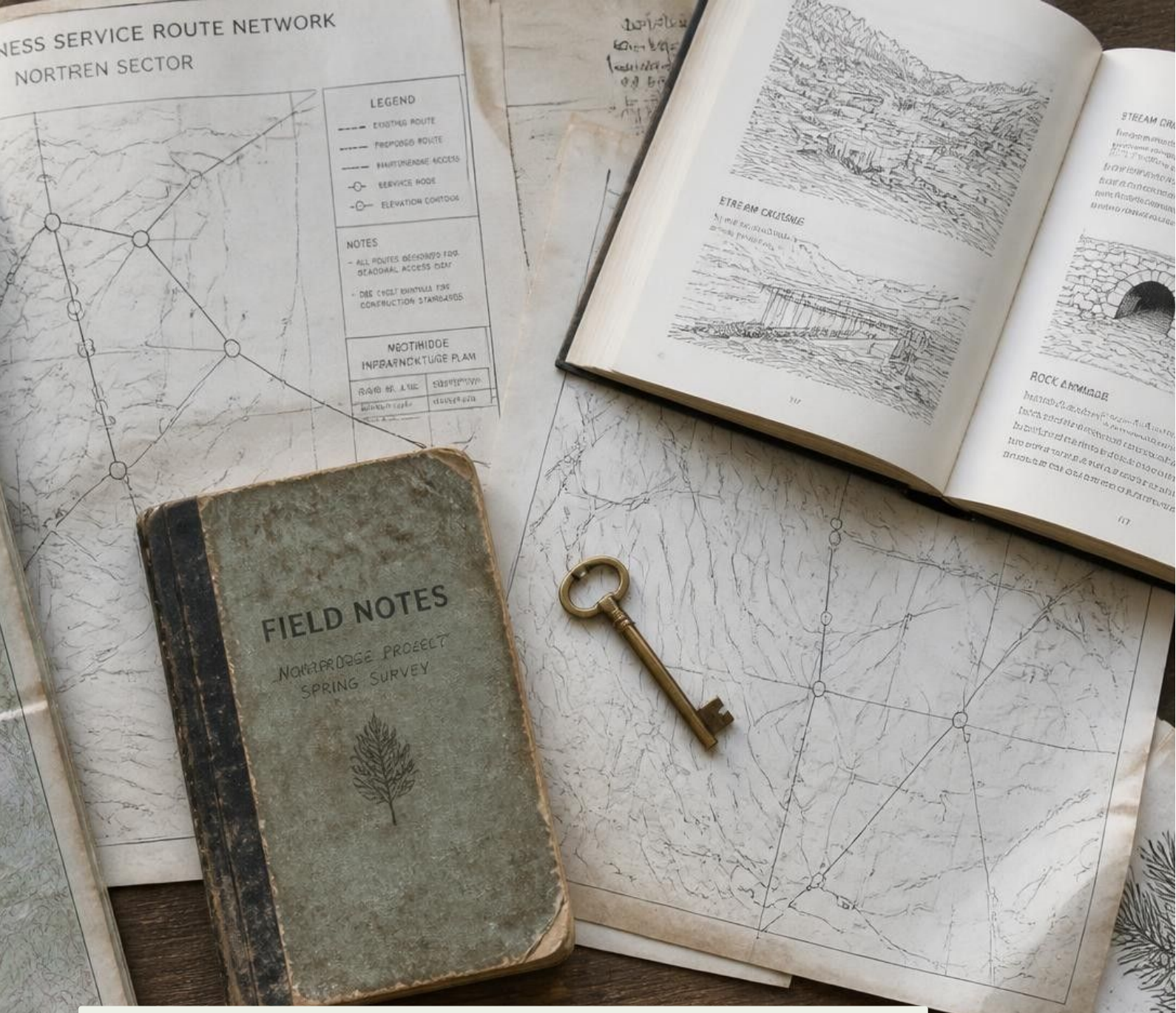


TECHNICAL STUDY GUIDE · SYSTEMS & ARCHITECTURE

Cloud Security Study Guide

A comprehensive reference covering core cloud architecture, virtualization, threat taxonomies, real-world attack vectors, defensive principles, and standard industry auditing tools.

11 Sections · Architecture · Threats · Defenses · Tooling

Cloud computing in one view

Cloud computing delivers scalable computing resources over ubiquitous networks, replacing capital infrastructure with elastic operational utilities.

NIST essential characteristics

The National Institute of Standards and Technology (NIST SP 800-145) defines cloud computing through five indispensable baseline properties:

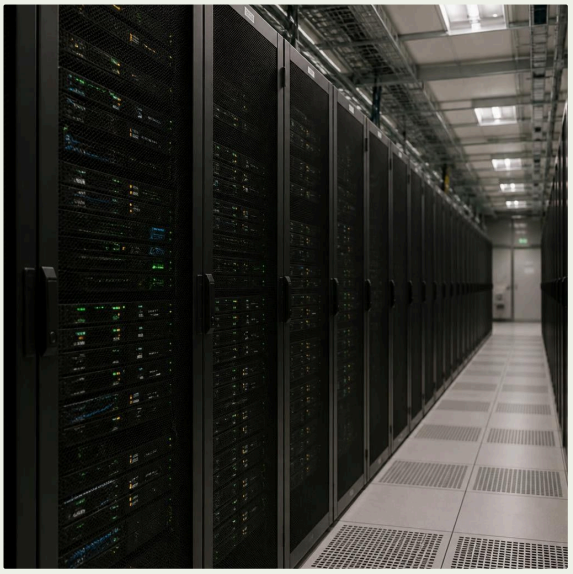
On-demand self-service	Consumers provision compute, storage, and networking automatically without human provider intervention.
Broad network access	Capabilities are available across standard networks and accessed via heterogeneous thin or thick client platforms.
Resource pooling	Multi-tenant physical and virtual resources are dynamically assigned and reassigned according to demand.
Rapid elasticity	Capabilities scale outward and inward elastically, appearing virtually infinite to the provisioner.
Measured service	Resource usage is automatically monitored, controlled, and billed transparently based on telemetry metrics.

Service models

IaaS (Infrastructure as a Service): Delivers raw processing, storage, and networking. The user configures OS and software (e.g., AWS EC2, Google Compute Engine).

PaaS (Platform as a Service): Supplies runtime environments, libraries, and managed tooling to deploy applications without OS administration (e.g., AWS Elastic Beanstalk, Google App Engine).

SaaS (Software as a Service): Turnkey end-user applications hosted and managed centrally by the provider (e.g., Microsoft 365, Salesforce).



Public, private, hybrid, and community hosting fabrics

Virtualization, containers and shared responsibility

Modern cloud abstraction separates workloads from physical metal, while operational boundaries strictly dictate defensive ownership.

Virtual machines vs. containers

Hypervisors (Type 1 & 2): Mediate between guest OS instances and physical hardware. Virtual machines carry a complete guest operating system, providing rigid isolation at the cost of boot latency and memory footprint.

Containers: Share the host Linux kernel while isolating user space via namespaces and cgroups. They offer rapid startup and low overhead but demand rigorous runtime container boundaries.

Serverless (FaaS): Event-driven micro-runtimes executing ephemeral code without user infrastructure management.

The shared responsibility rule

Security **of** the cloud remains the cloud service provider's contractual domain: physical hardware, data center facilities, cabling, power, and low-level virtualization fabrics.

Security **in** the cloud rests squarely on the customer: data classification, identity and access management, encryption keys, network firewall ingress, and guest OS patch cadence.

As organizations climb the stack from IaaS to SaaS, the provider absorbs more administrative liability, but data ownership never transfers.

Responsibility matrix across models

ARCHITECTURAL TIER	IAAS	PAAS	SAAS
Data & Access Governance	Customer	Customer	Customer
Application Logic & Code	Customer	Customer	Provider
Runtime & Middleware	Customer	Provider	Provider
Operating System & Patches	Customer	Provider	Provider
Virtualization & Physical Plant	Provider	Provider	Provider

Note: Identity and access management (IAM) configuration remains customer-controlled in every delivery model.

Cloud threats: where risk comes from

Unlike on-premises networks protected by physical perimeters, cloud exposures predominantly stem from configuration drift, identity sprawl, and programmatic interfaces.

01 Data breaches and catastrophic data loss

Unsecured object stores, publicly exposed snapshots, and inadequate offsite backups allow unauthorized data exfiltration or unrecoverable deletion during ransomware campaigns.

02 Misconfiguration and inadequate change control

The single most frequent origin of cloud compromise. Default credentials, overly permissive security groups (e.g., 0.0.0.0/0 on SSH/RDP), and orphaned public endpoints bypass perimeter defenses.

03 Insecure interfaces and control-plane APIs

Management APIs, CLI access keys, and microservice REST interfaces govern the infrastructure. Broken object level authorization (BOLA) or unauthenticated endpoints expose administrative controls.

04 Account hijacking and credential compromise

Credential stuffing, phishing, and hardcoded secrets checked into public source repositories allow threat actors to authenticate as valid operators, bypassing traditional network controls.

05 Insider threats, shadow IT, and visibility deficits

Engineers spinning up unsanctioned cloud subscriptions evade organizational logging, creating unmonitored blind spots outside the security operations center's telemetry collection.

Industry consensus: Over 80% of documented cloud breaches originate from customer misconfigurations and IAM credential exposure rather than flaws in provider hardware.

Defensive imperative: Emphasize continuous infrastructure as code (IaC) verification and automated identity governance over legacy perimeter filtering.

Shared technology and compliance risk

Multi-tenant designs aggregate risks across underlying physical platforms, creating collective systemic dependencies and stringent jurisdictional burdens.

ISOLATION

Multi-tenancy failures

Shared memory buses, hypervisors, and storage controllers create risks where flaws in virtualization logic or processor microarchitectures expose adjacent tenant workloads.

RESILIENCE

Lock-in & systemic outage

Proprietary APIs, specialized data formats, and steep data egress fees complicate disaster failover and multi-cloud portability when centralized provider regions degrade.

LEGAL

Regulatory & data residency

Regulations like GDPR, HIPAA, and PCI-DSS mandate strict sovereign geographic boundaries. Auto-replicating storage buckets can inadvertently violate cross-border data transfer laws.

DEPENDENCIES

Third-party supply chain

Container base images, community Terraform modules, and managed SaaS integrations introduce uninspected code pathways that inherit high-privilege access tokens.

Compliance frameworks mapped to cloud controls

STANDARD	PRIMARY MANDATE	CORE CLOUD CHALLENGE
GDPR (EU)	Privacy rights, data residency, and processing consent	Restricting cross-region telemetry and multi-zone bucket replication
HIPAA (US)	Protection of electronic Protected Health Information (ePHI)	Executing Business Associate Agreements (BAAs) and field-level encryption
PCI-DSS	Cardholder data environment (CDE) protection	Proving micro-segmentation and continuous audit logging in ephemeral instances

Cloud attacks: how threats become incidents

Adversaries weaponize cloud operational scale, turning administrative features and web services into avenues for persistence and financial exploitation.

ATTACK VECTOR	MECHANISM	OBSERVED OPERATIONAL IMPACT
DDoS & Economic Denial (EDoS)	Flooding elastic infrastructure endpoints with layer 7 or volumetric UDP/SYN floods	Severe billing spikes as auto-scaling groups scale out compute to absorb malicious ingress, degrading service availability.
Cryptojacking	Compromising IAM keys to provision GPU/high-compute instances running Monero miners	Massive API quota exhaustion and catastrophic compute invoices within hours of credential compromise.
Man-in-the-Cloud (MitC)	Stealing synchronization tokens (e.g., OAuth refresh tokens) rather than raw passwords	Persistent silent exfiltration of synced enterprise documents without alerting endpoint detection sensors.
XML/API Wrapping Attacks	Manipulating SOAP/XML signatures by injecting malicious elements while preserving original hash signatures	Bypassing web service validation layers to execute unauthorized administrative cloud commands.
Injection on Cloud Web Apps	Exploiting SQLi, NoSQLi, or Command Injection flaws within microservices	Extracting backend environment variables, IAM runtime tokens, and database credentials from managed datastores.

Defensive Takeaway: Shifting the Economic Balance

Cloud attacks often target the financial model rather than simply knocking servers offline. Defensive engineering requires rate-limiting APIs, budget alarms with automated shutdown triggers, and ephemeral short-lived credential exchange.

Attacks on tenants and infrastructure

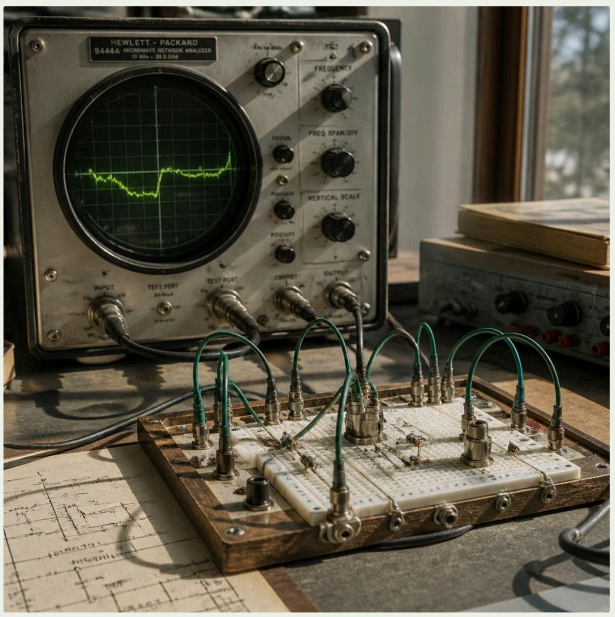
When attacks breach the software boundaries of virtualization or query internal metadata planes, adversaries attain systemic control.

Hardware & isolation attack mechanics

Side-Channel Attacks: Exploiting CPU microarchitectural timing variations (e.g., Spectre, Meltdown) across co-located VMs to extract cryptographic keys from shared memory buses.

Hypervisor & Container Escape: Leveraging software vulnerabilities in container runtimes (e.g., runC CVE-2019-5736) or VM drivers to break out of guest sandboxes into the host kernel.

Metadata Service Abuse (SSRF): Forcing web applications to query non-routable link-local endpoints (`169.254.169.254`) to retrieve temporary instance profile security tokens.



Microarchitectural side-channels expose co-tenant memory

Case Study: The 2019 Capital One Breach

Attack Vector	Server-Side Request Forgery (SSRF) against a misconfigured open-source Web Application Firewall (ModSecurity) running on AWS EC2.
Token Theft	The attacker coerced the WAF instance into querying the AWS Instance Metadata Service (IMDSv1), which returned temporary IAM role credentials.
Privilege Flaw	The instance's IAM role possessed excessive permissions, notably overbroad `s3:Sync` and `s3:ListBucket` access across unrelated customer databases.
Outcome & Defense	Over 100 million customer records exfiltrated. Industry responded by mandating **IMDSv2** (session-oriented, requiring PUT header tokens) and least-privilege IAM scopes.

Cloud security: core principles

Building a defensible cloud posture requires assuming breach, eliminating implicit trust, and systematically enforcing identity-centric barriers.

01 · IDENTITY FIRST

IAM & least privilege

Identity is the new perimeter. Enforce Role-Based Access Control (RBAC), eliminate static long-lived API keys, require phishing-resistant MFA, and mandate Just-In-Time (JIT) privilege elevation.

02 · CRYPTOGRAPHY

Comprehensive encryption

Encrypt data in transit using modern TLS (1.3 preferred) and at rest across object stores, block disks, and backups. Control key lifecycles using dedicated Hardware Security Modules (Cloud KMS / HSM).

03 · NETWORK

Zero Trust & segmentation

Isolate environments into distinct Virtual Private Clouds (VPCs). Use private subnets, restrict Security Groups to minimal ingress, and verify explicit authorization on every intra-service API request.

04 · VISIBILITY

Logging & response

Capture non-repudiable management plane activity (e.g., AWS CloudTrail), network flow logs, and workload execution traces. Feed streams to central immutable SIEMs for automated threat detection.

Architectural comparison: legacy vs. cloud-native defense

SECURITY DIMENSION	TRADITIONAL ON-PREMISES	ZERO TRUST CLOUD ARCHITECTURE
Network Boundary	Perimeter firewall (castle-and-moat)	Micro-segmented VPCs, service-mesh mTLS
Access Verification	VPN authentication at entrance	Continuous context-aware token inspection
Credentials	Static service passwords, AD service accounts	Ephemeral OIDC tokens, IAM instance roles

Governance, compliance and best practices

Systemic security relies on codified baseline frameworks and automated deployment checks rather than manual, point-in-time checklist reviews.

Standard cloud compliance frameworks

01 CSA Cloud Controls Matrix (CCM)

A cybersecurity control framework mapping cloud security concepts across 17 domains and 197 objectives, providing foundational criteria for the STAR registry.

02 ISO/IEC 27017 & 27018

Code of practice extending ISO 27001 specifically for cloud service providers and customers, focusing on multi-tenancy controls and public cloud PII protection.

03 NIST SP 800-53 & FedRAMP

Rigorous federal catalog of security and privacy controls governing government cloud authorizations across low, moderate, and high impact tiers.

04 SOC 2 Type II (Trust Services Criteria)

Independent third-party attestation evaluating security, availability, processing integrity, confidentiality, and privacy over a minimum six-month operating period.

Shift-left: infrastructure as code (IaC) verification

Integrating security into continuous integration and deployment pipelines prevents misconfigurations before resources ever reach production environments.

Static IaC Scanning	Tools like **Checkov**, **tfsec**, and **KICS** evaluate Terraform, CloudFormation, and Helm templates for exposed ports, unencrypted volumes, and missing logging.
Immutable Baselines	Enforce Center for Internet Security (CIS) benchmarks on golden virtual machine images and base container images.
Disaster Recovery (DR)	Regularly validate Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) via multi-region replication and automated restore drills.

Cloud security tools by job

A multi-layered defense requires specialized tooling organized across posture management, runtime workload isolation, identity, and SIEM.

01 Posture Management (CSPM & CNAPP)

Continuously checks cloud APIs for misconfigurations, drift, and regulatory non-compliance.
Key Tools: Wiz, Palo Alto Prisma Cloud, AWS Security Hub, Microsoft Defender for Cloud.

02 Workload & Container Protection (CWPP)

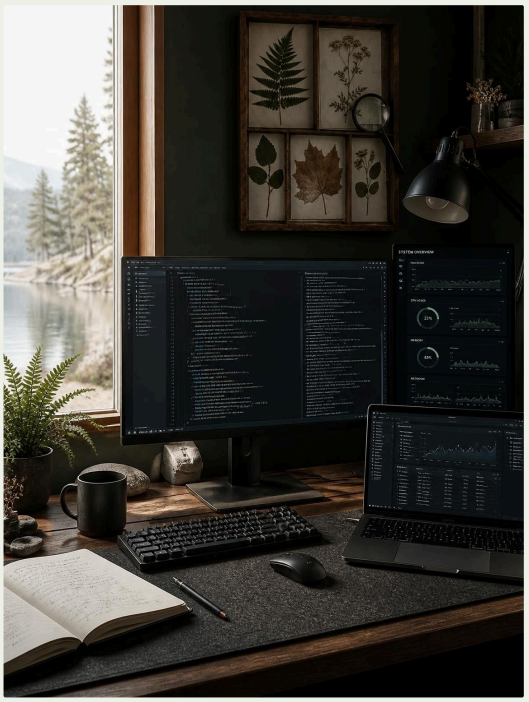
Monitors containers, VMs, and clusters for kernel anomalies and vulnerabilities.
Key Tools: Aqua Security, Falco (eBPF behavioral runtime), Trivy (CVE scanner).

03 Identity & Access Governance (CIEM)

Maps IAM entitlements, flags overprivileged roles, and enforces cross-cloud access.
Key Tools: AWS IAM Identity Center, Microsoft Entra ID, Okta, CyberArk.

04 Cloud Detection, SIEM & Threat Intelligence

Aggregates multi-account audit logs; machine learning detects rogue activity.
Key Tools: Splunk Enterprise Security, Microsoft Sentinel, AWS GuardDuty.



Security operations tooling infrastructure

TOOL CLASS	PRIMARY TELEMETRY	PRIMARY REMEDIATION
CSPM	Cloud management control-plane APIs	Automated policy revert & alert tickets
CWPP	Host kernel events, syscalls, container logs	Pod termination & process quarantine
SIEM	Aggregated multi-source event logs	Automated SOAR playbook execution

Pen-testing and auditing tools

Proactive verification requires actively probing cloud fabrics with specialized security scanners and exploitation frameworks.

AUDITING & POSTURE

Scout Suite & Prowler

Scout Suite: Open-source multi-cloud security auditing tool querying APIs across AWS, Azure, and GCP to produce a clear HTML vulnerability risk report.

Prowler: CLI-based security assessment tool dedicated to AWS and Azure CIS benchmarks, GDPR, and HIPAA compliance checks with automated output.

EXPLOITATION & APPLICATION

Pacu, Burp & Nmap

Pacu: Modular exploitation framework designed specifically for AWS penetration testing, automating privilege escalation, data exfiltration, and evasion.

CloudSploit: Real-time configuration scanner identifying exposed ports and insecure permissions.

Burp Suite & Nmap: Classic web interception proxies and port scanners to audit exposed cloud endpoints.

Study guide review questions

01	**Shared Responsibility:** If an attacker accesses an unencrypted database hosted on an AWS EC2 instance via leaked IAM credentials, which party is contractually liable?
02	**Attack Vectors:** How does IMDSv2 mitigate the Server-Side Request Forgery (SSRF) vector that compromised Capital One's WAF in 2019?
03	**Tool Classification:** Distinguish the operational scope of a CSPM (e.g., Wiz) from a runtime CWPP (e.g., Falco).
04	**Architecture:** Why does containerization introduce different kernel-isolation risks compared to Type-1 hypervisor virtualization?

> **Core Takeaway:** Security in the cloud is an active discipline of continuous verification, identity governance, immutable automation, and defense-in-depth across software layers.